

Security Lake, OCSF and what sits on top

Normalising every log source into one schema – and the analytics layer that makes it worth doing.

Security Lake's product is not storage. It is
normalisation.

What Security Lake actually does

- ◆ Runs **ETL** on raw source data, converting it to **Apache Parquet** and the **OCSF schema**.
- ◆ Stores it in **your own S3 buckets, in your account**. You keep ownership and control of the data.
- ◆ A **separate bucket per Region**. Data is stored in the Region it was generated in.
- ◆ Registers a **Lake Formation table per source** via the Glue Data Catalog, so Athena can query it immediately.
- ◆ Default encryption is **SSE-S3**. A customer managed key is optional and must be chosen deliberately.

ON THE EXAM

Parquet plus a catalogued table is why this is queryable on arrival. There is no crawler to write and no schema to infer.

Eight natively supported AWS sources

SOURCE	WHAT IT CARRIES
CLOUD_TRAIL_MGMT	CloudTrail management events
S3_DATA	CloudTrail S3 data events
LAMBDA_EXECUTION	CloudTrail Lambda execution events
VPC_FLOW	VPC Flow Logs
ROUTE53	Route 53 Resolver DNS query logs
SH_FINDINGS	Security Hub findings, including 50+ integrated partners
EKS_AUDIT	EKS audit logs
WAF	AWS WAF logs

ON THE EXAM

CloudTrail arrives as three separate sources. You can take management events without paying to normalise every S3 data event.

OCSF, and getting your own data in

- ◆ **Open Cybersecurity Schema Framework** – an open standard from AWS and other security vendors, not an AWS format.
- ◆ Events group into **categories**, then **event classes**. A firewall log and a flow log both become network activity.
- ◆ **Custom sources** bring third-party and on-premises data in. **You convert to OCSF first**; Security Lake will not.
- ◆ **One custom source per OCSF event class**. Authentication and network logs are two sources.
- ◆ SCS-C03 skill 3.1.4 names **ingesting data in OCSF format** explicitly.

ON THE EXAM

An open schema means your firewall vendor emits it too. That is what enables cross-vendor correlation.

Regions, rollups and accounts

- ◆ A **contributing Region** generates data. A **rollup Region** consolidates data from one or more contributing Regions.
- ◆ AWS names the reason plainly: rollup Regions help you **meet regional compliance requirements**.
- ◆ You can have **more than one rollup Region** – for example an EU rollup and a US rollup that never mix.
- ◆ **Delegated administrator** for AWS Organizations, as with every other service in this domain.
- ◆ Retention is configurable per source, with **automated storage tiering** to cut long-term cost.

ON THE EXAM

Rollup Regions are the data residency answer. One query surface per jurisdiction, rather than one query surface for everything.

Subscribers: two ways to consume the lake

- ◆ **Query access** – the subscriber queries tables in place through Lake Formation. Analysts, Athena, a BI tool.
- ◆ **Data access** – the subscriber is notified as new objects are written and reads them. This is how a SIEM consumes the lake.
- ◆ A data access subscriber gets an **SQS queue**, an **IAM role ARN** and an **external ID**.
- ◆ That external ID is not decoration. It is the confused deputy defence, and it returns in module 21.
- ◆ Subscribers can be scoped to specific sources, so a vendor sees flow logs and not CloudTrail.

ON THE EXAM

Query access is people asking questions. Data access is a machine taking a copy. The scenario will make clear which.

Security Lake, or CloudTrail Lake?

SECURITY LAKE WHEN

Many sources, one schema

- Flow logs, DNS, WAF, findings, third-party
- You need cross-source correlation
- A SIEM or partner tool consumes it
- Data residency drives rollup Regions

CLOUDTRAIL LAKE WHEN

API activity, queried directly

- The question is who called what
- SQL in place, no analytics stack
- Config items and Audit Manager evidence
- Immutable store, retention to 10 years

THE TIEBREAKER

One source or many? CloudTrail Lake is deep on API activity. Security Lake is broad across everything that emits a log.

What you put on top

- ◆ **Athena** – SQL over the Lake Formation tables. Serverless, pay per query. The default answer.
- ◆ **OpenSearch Service** – search, alerting, rich dashboards. A cluster you size, patch and pay for continuously.
- ◆ **Amazon Managed Grafana** – named in skill 1.2.5. One dashboard over CloudWatch, OpenSearch, Athena and Prometheus.
- ◆ Managed Grafana added **customer managed key** encryption for workspace data, February 2026.
- ◆ Rare queries favour Athena. Constant queries favour a cluster. That is the whole trade.

ON THE EXAM

'Occasional investigation' is Athena. 'A wall the SOC watches' is OpenSearch or Grafana.

Honest limits

- ◆ **Normalisation loses fidelity.** OCSF keeps the raw record, but a query written against the schema sees the mapped fields.
- ◆ **It is another copy.** You still pay to store the originals, and you now have a second dataset to secure.
- ◆ **Not real time.** ETL runs on a schedule. This is investigation and correlation, not alerting.
- ◆ For alerting you still want **EventBridge** on the finding, as in module two.
- ◆ Custom source conversion is **your engineering problem**, and for a chatty third-party source it is not trivial.

ON THE EXAM

Security Lake is where you go to ask a question about last Tuesday. It is not where you find out about right now.

A manufacturer runs Security Lake with all native AWS sources enabled across 40 accounts. It also operates a third-party next-generation firewall in each factory and an on-premises Active Directory estate.

After an incident, analysts spent four days manually correlating firewall logs against VPC Flow Logs because the timestamp formats and field names differ. The security architect wants future investigations to run as a single query across AWS and non-AWS data.

What should the architect implement?

- ☐ A CloudWatch Logs subscription filter shipping firewall logs to OpenSearch alongside AWS logs
- ☐ A CloudTrail Lake event data store with the firewall logs imported as integration events
- ☐ Custom sources in Security Lake, with the firewall and AD logs converted to OCSF before sending
- ☐ An S3 bucket for the firewall logs with a Glue crawler and Athena views joining the two datasets

◆ PAUSE AND DECIDE

What should the architect implement?

- A

 Subscription filter to OpenSearch
Puts both datasets in one place and leaves them in two different shapes. Co-location is not correlation – the field mismatch survives the move.
- B

 CloudTrail Lake event data store
CloudTrail Lake is built around API activity. Firewall and Active Directory logs are not AWS API calls and do not belong there.
- C

 Custom sources converted to OCSF
Correct. Conversion to a shared schema is exactly the problem. Firewall and flow data both become network activity with identical field names.
- D

 S3 bucket, Glue crawler, Athena views
The build-it-yourself version of Security Lake. It works, and you own the schema mapping, the crawler and the views forever.

THE SIGNAL

'Timestamp formats and field names differ' is a schema problem stated in plain words. Only one option changes the schema.

A bank operates in twelve AWS Regions. Under its interpretation of EU data protection obligations, security telemetry generated in European Regions must not be stored outside the EU. Telemetry from its Asia-Pacific and US Regions has no such restriction.

The global security operations centre wants as few query surfaces as possible. Today analysts run the same Athena query twelve times, once per Region, and paste results into a spreadsheet.

How should the bank configure Security Lake?

- ☐ A One rollup Region in us-east-1 consolidating all twelve Regions, with SSE-KMS encryption
- ☐ B No rollup Regions; query each contributing Region separately as they do today
- ☐ C One rollup Region per contributing Region, so each has a dedicated consolidation target
- ☐ D Two rollup Regions – one in the EU for the European Regions, one elsewhere for the rest

◆ PAUSE AND DECIDE

How should the bank configure Security Lake?

- A

 One rollup Region in us-east-1 for all twelve
Solves the query problem and breaks the residency requirement. Encryption protects confidentiality; it does not change where bytes are stored.
- B

 No rollup Regions
This is the status quo the scenario is complaining about. Compliant, and it leaves twelve query surfaces and a spreadsheet.
- C

 One rollup Region per contributing Region
Consolidating one Region into itself achieves nothing but cost. A rollup Region exists to serve several contributing Regions.
- D

 Two rollup Regions, EU and non-EU
Correct. Two query surfaces instead of twelve, and European telemetry never leaves the EU. AWS names regional compliance as the reason rollups exist.

THE SIGNAL

'As few as possible' is not 'one'. Requirements that conflict usually want the smallest number that satisfies both, not the smallest number.

A healthcare group has Security Lake running with a rollup Region. It has bought a third-party SIEM that must receive new security telemetry continuously, within minutes of it landing, and process it in the vendor's own platform.

The vendor's account is outside the group's AWS Organization. Security requires that the vendor can read VPC Flow Logs and Route 53 logs but not CloudTrail management events, and that the vendor cannot be tricked into acting on behalf of another customer.

How should the group give the SIEM access?

- A Grant the vendor query access through Lake Formation, scoped to the two tables
- B Create a data access subscriber scoped to those sources, using the generated role and external ID
- C Add a bucket policy granting the vendor account s3:GetObject on the Security Lake bucket
- D Generate presigned URLs for new objects and send them to the vendor by SNS

◆ PAUSE AND DECIDE

How should the group give the SIEM access?

- A

 Query access through Lake Formation
Right service, wrong mode. Query access lets the vendor ask questions in place. The SIEM must ingest the data into its own platform.
- B

 Data access subscriber with role and external ID
Correct. SQS notifies on new objects for continuous delivery, source scoping enforces the read restriction, and the external ID answers the confused deputy requirement.
- C

 Bucket policy granting s3:GetObject
No notification, so the vendor must poll. Bucket-level access is hard to scope per source, and there is no external ID protection.
- D

 Presigned URLs pushed via SNS
A custom pipeline reinventing what a subscriber does, with URL expiry to manage and credentials embedded in links.

THE SIGNAL

Three requirements, three subscriber features. 'Cannot be tricked into acting for another customer' is the textbook description of an external ID.

An energy company has 200 accounts across six Regions. During investigations, analysts need to correlate VPC Flow Logs, Route 53 DNS query logs, CloudTrail management events and Security Hub findings in a single query, over two years of history.

Investigations happen a few times a month. The company has no data engineering team and has said it will not operate a search cluster. Cost should scale with use rather than being fixed.

What should the company implement?

- ☐ A Security Lake with a rollup Region, queried with Athena
- ☐ B A CloudTrail Lake organization event data store with a two-year retention period
- ☐ C An Amazon OpenSearch Service domain fed by subscription filters from all 200 accounts
- ☐ D Subscription filters to a central S3 bucket with Glue crawlers and Athena

◆ PAUSE AND DECIDE

What should the company implement?

- A

 Security Lake with a rollup Region, queried with Athena
Correct. All four sources are native, OCSF makes them correlatable in one query, the rollup handles six Regions, and Athena bills per query.
- B

 CloudTrail Lake organization event data store
Excellent for CloudTrail. It does not ingest VPC Flow Logs, DNS query logs or Security Hub findings, so three of the four sources never arrive.
- C

 OpenSearch domain fed by subscription filters
Ruled out twice. The company will not operate a cluster, and a domain is fixed cost running constantly for queries that happen a few times a month.
- D

 Subscription filters, S3, Glue crawlers and Athena
Plausible until you notice there is no data engineering team. It also leaves four schemas unreconciled, which is the actual problem.

THE SIGNAL

Four constraints, four eliminations. Read the constraints as a filter and often only one option survives all of them.

Five things to carry forward

- ◆ **The schema is the product.** Co-locating logs is not correlating them.
- ◆ **You convert custom sources to OCSF, not Security Lake.** One custom source per event class.
- ◆ **Rollup Regions are the data residency answer.** You can have more than one, and often should.
- ◆ **Query access is people asking. Data access is a machine copying.** The latter brings SQS, a role and an external ID.
- ◆ **Security Lake is not real time.** Alerting is still EventBridge on the finding.

ON THE EXAM

Next: why the log is not there. Troubleshooting detection, and the six reasons a scenario has no evidence in it.